

2.4 Back Office Data Flow Security

Control Type: Mandatory	Applies to architecture:	A1	A2	A3	A4	B
		•	•	•	•	
<u>Control Definition</u> Control Objective: Ensure the confidentiality, integrity, and authenticity of data exchanged between back-office first hops and on-premises or remote user's Swift infrastructure components. In-scope components: - Data exchange layer: that is direct or indirect, through bridging servers, flows of business transactions between the user's Swift infrastructure components and back office first hops: - New types (that can rely on secure protocols or mechanisms) of direct, or point to point, flows implemented, as from 2025, between a back-office first hop and a user's Swift infrastructure component - Direct flows between a bridging server and a user's Swift infrastructure component - Flows between bridging servers linking a back-office first hop and a user's Swift infrastructure component [Advisory: existing (so-called legacy) direct flows between a back-office first hop and a user's Swift infrastructure component] [Advisory: existing (so-called legacy) direct flows between a back-office first hop and a bridging server]. - Flows towards New HSM. Notes: - The above advisory components, that is the existing (or legacy) back-office flows, will become mandatory in scope, in a subsequent version (tentatively the CSCF v2028). - The Appendix H illustrates the various flows and provides a phased approach to implement this control, Swift recommends to already start the phasing by (i) identifying all relevant flows in scope and by (ii) using a risk-based approach to prioritise and schedule the potential next steps. Risk Drivers: - loss of sensitive data confidentiality - loss of sensitive data integrity - unauthenticated system traffic - unauthorised access						
<u>Implementation Guidance</u> Control Statement: Confidentiality, integrity, and authentication mechanisms (at system, transport, message, or data level) are implemented to protect data exchanged between user's Swift infrastructure components and the back-office first hops they connect to. Control Context: Protection of data exchange, flows or connections, between the back-office first hops as seen from the Swift or customer secure zone and the Swift infrastructure, safeguards against person-in-the-middle attack, unintended disclosure, modification, and data access while in transit. Implementation Guidelines: The implementation guidelines are common methods to apply the relevant control. The guidelines are a helpful way to begin an assessment but should never be considered as an audit checklist as each user's implementation may vary. Therefore, in cases where some implementation guidelines elements are not present or partially covered, mitigations as well as particular environment specificities must be						

considered to properly assess the overall compliance adherence level (as per the suggested guidelines or as per the alternatives).

- Inventorise data exchanged that is direct or indirect flows, between the back-office first hops and the user's Swift-related components, on premises or remote.
 - Assess the security in terms of confidentiality, integrity and authenticity of each flow.
 - Data exchanged between a back-office first hop and a user's Swift infrastructure component is protected by implementing **one or a combination of the following two methods**:
 - **(1) End-to-end protection** that is:
 - a secure mechanism (for example AES-GCM based Local Authentication, XML DSIG, or similar) that ensures integrity, confidentiality and authentication at the data level. As such,
 - the authentication and authorisation are validated by the recipient of the data
 - prevention or detection of possible replay attacks (when same protected data is resubmitted) must be considered.

OR

 - when there is a direct (point to point) connectivity between the back-office first hop and the user's Swift infrastructure component, a secure protocol that ensures the authentication, integrity and confidentiality of the connection. This can be achieved for example, by using Local Authentication (LAU) in combination with a confidentiality protection²⁴, authenticated API calls over TLS or by using two-way TLS.
 - **(2) Protection at each leg** of the flow supported by one or several bridging servers between the back-office first hop and the user's Swift infrastructure component, that is:
 - a secure mechanism or a secure protocol as per the above, or a combination, that protects each leg or segment in the flow,

AND

 - the bridging server(s), **guardian(s) of the data exchange**, are secured by implementing the controls listing 'bridging server' in their in-scope components section.
- For the flows that are not properly protected, define a plan to secure those flows, considering for their prioritisation a risk based approach (supported by a risk assessment), to:
 - Implement secure mechanisms or protocols offered by the interfaces, connectors, or bridging servers
 - Migrate opportunistically legacy flows to secure mechanisms or protocols
 - Mitigate (in line with the supporting risk assessment) the risk of back-office system spoofing or message injections through systems or network connectivity means.
- Secure protocols use current, commonly accepted cryptographic algorithms (for example, AES²⁵ or ECDHE²⁶) with key lengths in line with the current best practices. For more information about cryptographic algorithms that support secure protocols, see the [Knowledge Base article 5021566](#).
- Credentials and private or bilateral (cryptographic) keys used, and usually stored, by applications to secure flows are protected. This can be achieved through a large spectrum of methods, from definition and usage of secure coding guidelines to the use of specific solutions such as KMS, secured based on the user's risk management.

²⁴ Such as one-way TLS where the sender validates the genuine recipient

²⁵ Advanced Encryption Standard

²⁶ Elliptic Curve Diffie-Hellman Ephemeral